

自主决策通用防御智能体 架构设计方案

基于 PentAGI 架构分析的建设思路 | 2026-05-09

目标：构建面向多变真实网络环境的自主决策通用智能体，作为网络安全从业人员的智能增强伙伴，实现从威胁感知、分析研判到响应处置的全闭环自主操作，推动网络安全防御体系从自动化到智能化的根本性跃升。

一、PentAGI 的启示与差距

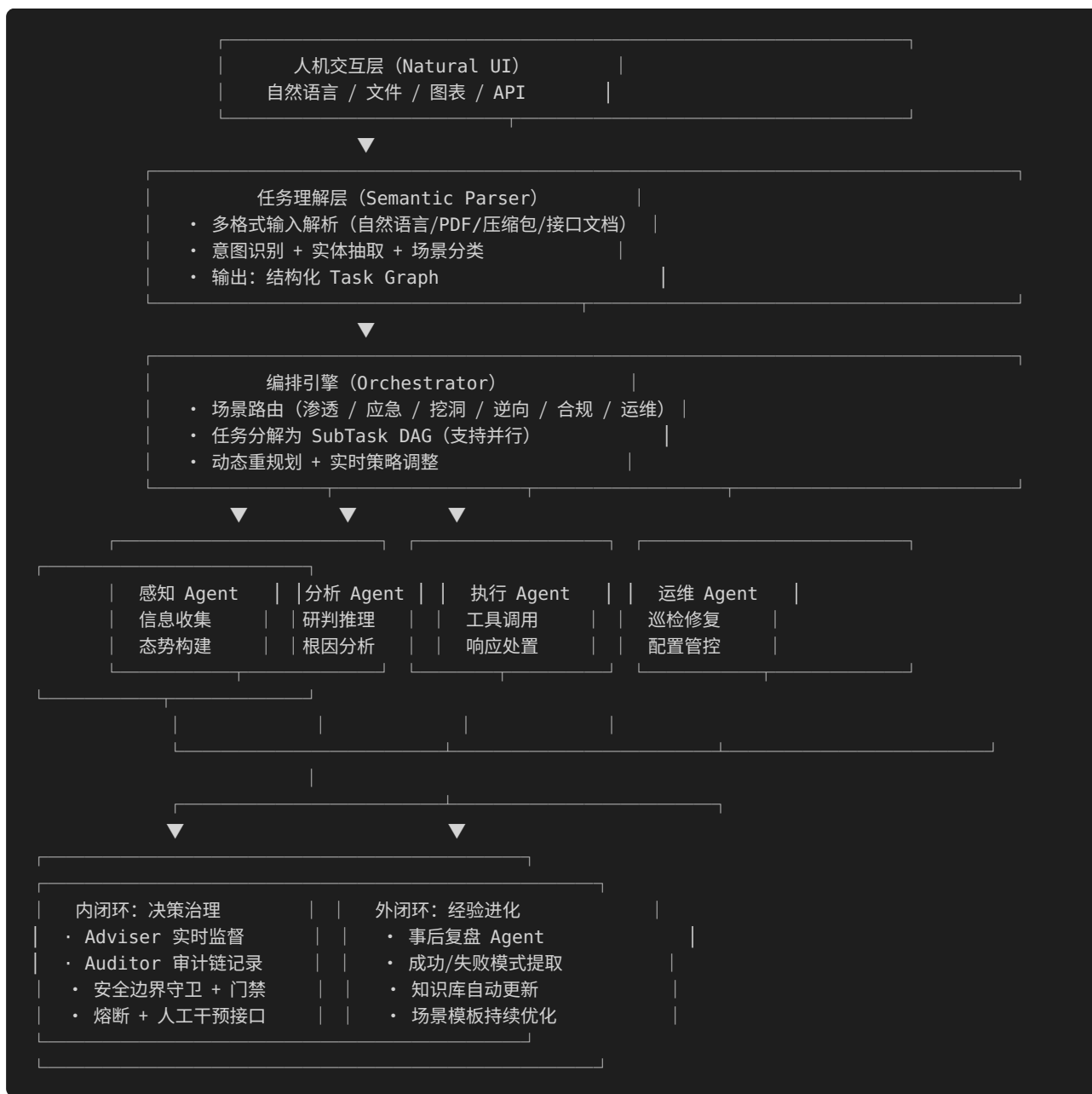
1.1 可复用模式

机制	PentAGI 实现	借鉴价值
多 Agent 分层协作	Researcher → Developer → Executor 三段流水线	感知→分析→执行的认知分层可复用
四层监督机制	Adviser/Planner/Limits/Reflector	多层决策质量控制的工程范式，小模型场景提升 2x
ChainAST 消息压缩	结构化分段摘要 + QA 保留 + 尾部保留	长对话上下文管理的可靠方案
三类记忆联动	长期(向量)/工作(上下文)/情景(历史)记忆闭环	知识积累与经验复用的核心基础设施
沙箱隔离执行	Docker + 独立网络 + 双节点部署	安全操作的基础保障

1.2 关键差距

- **PentAGI 是攻击视角**，缺少防御场景的认知框架与知识体系
- **决策不具备可解释性**——没有审计链路，无法追溯每个决策的证据依据
- **单一渗透场景**，不支持应急响应、逆向分析、漏洞挖掘等多场景动态切换
- **缺乏对抗鲁棒性**——没有对抗干扰防护、操作门禁、熔断机制
- **线性 Flow 模型**，无法支持并行子任务和动态重规划

二、总体架构：分层认知 + 双闭环



架构核心思想

- **分层认知**: 任务理解 → 编排决策 → 感知/分析/执行, 每层各司其职
- **双闭环**: 内闭环 (实时决策治理) 保证每次决策可靠; 外闭环 (事后经验进化) 保证系统持续成长
- **DAG 编排**: 替代 PentAGI 的线性 Flow, 支持并行子任务和失败时的局部重规划
- **场景感知**: 路由到不同场景知识库, 加载对应的工具集、Playbook 和历史案例

三、核心模块详细设计

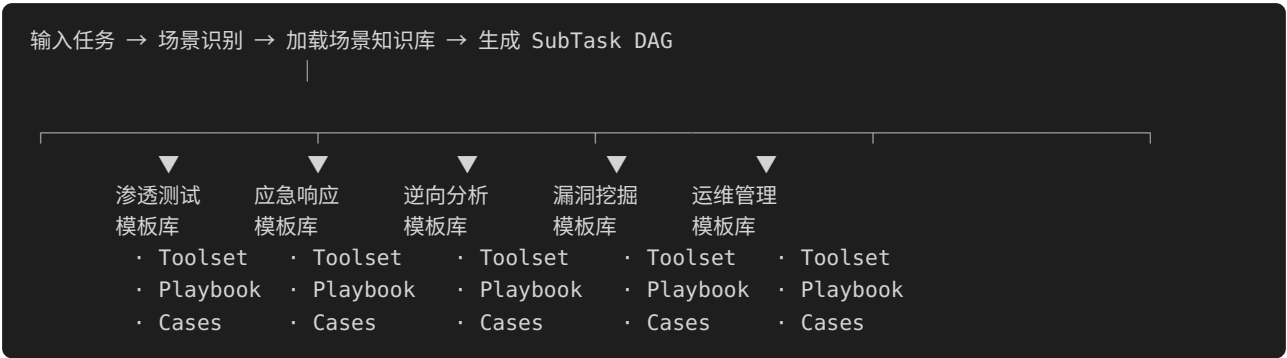
3.1 任务理解层

这是 PentAGI 最薄弱的一环，也是防御体系最关键的部分——防御任务往往来自告警、工单、报告等多种非结构化输入。

能力	实现方案
多格式输入解析	独立 Parser Pipeline：自然语言 → Markdown/PDF → 压缩包 → API 接口文档，统一输出结构化 Task Graph
意图识别	LLM + Few-shot 将用户输入映射到场景标签（渗透测试/应急响应/漏洞挖掘/逆向分析/合规检查），并识别关键约束（时间窗口、影响范围、优先级）
实体抽取	提取 IP、域名、CVE 编号、工具名、文件路径、时间约束、资产标识等，形成结构化 Context Object
任务规划	借鉴 PentAGI Planner Agent，增加 场景模板库 作为先验约束，避免 LLM 自由发挥导致偏离场景

3.2 场景路由与编排引擎

PentAGI 只有单一渗透流程。防御体系需要多场景动态路由。



机制	设计
DAG 而非线性 Flow	允许并行子任务——例如同时进行信息收集和漏洞库查询；子任务间用依赖关系连接
动态重规划	当某个子任务失败或发现新信息（如扫描发现意外端口），Planner 自动重新规划下游 DAG
场景知识库	每个场景独立维护 Tool Profile（可用工具及参数约束）、Playbook（标准操作流程）、历史案例（向量化）
优先级调度	应急响应场景下，信息收集和阻断类 Action 自动获得更高优先级

3.3 Agent 角色体系

在 PentAGI 的 11 种 Agent 基础上，针对防御场景扩展：

Agent	PentAGI 原有	防御体系新增/强化职责	调用 上限
Perceiver（感知）	无	态势感知：日志采集、流量分析、资产发现、告警聚合	100
Analyst（分析）	无	研判推理：告警关联分析、攻击链还原（ATT&CK映射）、根因定位、影响评估	100
Responder（处置）	无	响应执行：流量阻断、主机隔离、补丁修复、服务恢复	100
Researcher（研究）	有	扩展：支持防御侧威胁情报查询、CVE 漏洞库比对、IOC 关联	20
Developer（规划）	有	强化：场景感知的多策略规划，生成带有置信度评分的候选方案	20
Executor（执行）	有	保持：工具调用与结果处理，增加操作前后的状态校验	100
Adviser（监督）	有(Beta)	强化：增加安全边界守卫（禁止操作白名单外命令）、风险阈值拦截、异常行为检测	20
Reflector（反思）	有	保持：LLM 调用失败时的反思纠错	20
Auditor（审计）	无	核心新增： 记录每个决策的证据链、生成可审计的决策日志、关键操作门禁确认	20
Memorist（记忆）	有	保持：向量存储写入/检索，增加防御经验模式存储	20
Operator（运维）	无	核心新增： 系统健康巡检、配置合规检查、补丁与版本管理、备份恢复、资源容量规划、服务启停与编排、日志轮转与清理、证书与密钥生命周期管理	100

3.4 运维 Agent 详细设计（Operator）

运维 Agent 是防御体系的**基础保障层**，负责系统的日常健康维护与配置管控。不同于 Perceiver/Analyst/Responder 面向安全事件，Operator 面向系统本身的可靠性和合规性。

子能力	功能描述	典型工具/操作
健康巡检	定期检查系统、服务、进程运行状态，自动识别异常并生成巡检报告	systemctl status, kubectl get pods, docker ps, curl health endpoint, top/htop
配置合规检查	对照安全基线（CIS/NIST/等保）自动审计系统配置，标记不合规项	lynis, openscap, cis-benchmark rules, 自定义合规脚本
补丁与版本管理	扫描可用更新，评估风险等级，生成升级计划，执行灰度升级	apt/yum update check, CVE-version mapping, canary deploy, rollback
备份与恢复	自动化数据备份策略管理，定期校验备份完整性，灾难恢复演练	pg_dump, restic, velero, snapshot, S3 sync
资源容量规划	监控 CPU/内存/磁盘/网络使用趋势，预测瓶颈并提前扩容建议	Prometheus metrics, df -h, iostat, capacity forecast model
服务启停与编排	按依赖顺序安全启停服务，处理滚动更新和零停机部署	docker compose, kubectl, systemctl, ansible playbook
日志轮转与清理	管理日志保留策略，自动轮转归档，清理过期数据和临时文件	logrotate, journalctl --vacuum, find + rm, tmpwatch
证书与密钥管理	监控 TLS 证书到期时间，自动续期或告警；密钥轮换与合规存储	certbot, openssl, vault, aws secrets manager

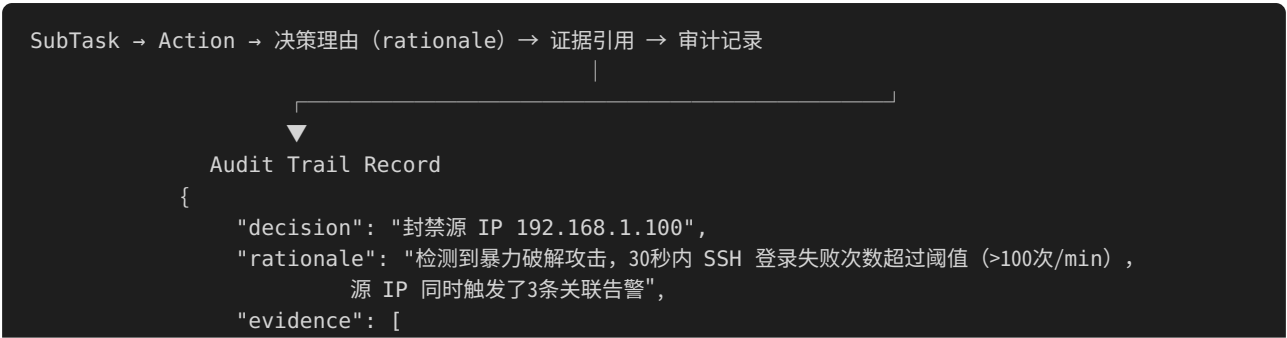
运维 Agent 与其他 Agent 的协作关系：

- → **Perceiver**：接收巡检发现的异常指标，触发感知 Agent 进行深度态势分析
- → **Responder**：当发现配置漏洞或过期组件时，将修复任务转交处置 Agent 执行
- → **Auditor**：巡检结果和配置变更记录同步到审计链，确保运维操作可追溯
- → **Memorist**：将系统健康基线和最佳配置模式存入长期记忆，用于异常检测基准

四、决策可解释性与审计体系（核心创新）

这是本方案与 PentAGI 最大的区别点，也是课题的核心竞争力所在。

4.1 审计链模型



```

        {"type": "alert", "id": "ALERT-2026-001", "rule": "SSH_BRUTE_FORCE"},
        {"type": "log_snippet", "source": "/var/log/auth.log", "lines": "234-256"},
        {"type": "threat_intel", "source": "AbuseIPDB", "score": 0.94}
    ],
    "confidence": 0.92,
    "agent_id": "responder-03",
    "task_id": "TASK-IR-2026-0042",
    "timestamp": "2026-05-09T10:30:00Z",
    "human_approval_required": false
}

```

4.2 实现机制

层级	机制	说明
LLM 输出层	强制 Rationale 输出	System Prompt 要求每个 Action 必须包含 rationale 字段，说明决策依据和推理过程
工具执行层	自动证据关联	工具执行输出（终端日志、API 响应）自动关联到对应决策记录，形成完整证据链
操作门禁层	分级管控	高风险操作（阻断流量、删除数据、修改配置）必须经 Auditor Agent 确认；可配置人工审批阈值
存储层	审计日志持久化	所有决策记录存入 PostgreSQL + Neo4j 图中，支持按任务/时间/Agent 多维追溯
展示层	决策链路可视化	前端以时间线+证据节点图形式展示，用户可点击每个决策查看完整的推理链和引用证据

4.3 安全操作分级

风险等级	操作示例	管控措施
低（只读）	查询日志、扫描端口、检索 CVE	自动执行，无需审批
中（影响小）	创建隔离 VLAN、修改非生产防火墙规则	Auditor 自动审批 + 事后审计
高（影响大）	阻断生产流量、隔离核心服务器、删除文件	Auditor 审查 + 人工确认（可配置自动审批阈值）
危险（不可逆）	DROP 数据库表、卸载安全组件、修改系统内核参数	强制人工审批，不允许自动执行

五、运行鲁棒性设计

机制	设计	解决的问题
对抗干扰防护	Agent 输入加入完整性校验层：检测 Prompt Injection 尝试、异常指令模式、结构化字段篡改	防止攻击者通过污染日志或告警来误导 Agent
状态快照与回滚	每个 Task 完成时自动保存状态快照（DAG 进度 + 工具输出 + Agent 状态），失败时回滚到最近检查点	长任务中断后不需要从头开始
熔断机制	Adviser 检测到连续异常决策（3次高风险操作或5次工具调用失败），自动暂停并请求人工介入	防止 Agent 在异常状态下持续产生错误决策
确定性保证	关键推理链路使用 Temperature=0 + 固定 seed，确保相同上下文产生相同输出	满足审计可复现性要求
行为复现	完整的 Action Log + Message Chain 序列化，支持逐步骤回放，所有状态可复原	事后复盘和合规审计
工具调用去重	借鉴 PentAGI 重复检测器，防止 Agent 陷入无效循环	避免资源浪费和超时

六、记忆与知识体系

记忆类型	存储介质	内容	更新机制
短期工作记忆	会话上下文	当前任务 DAG 状态、活跃 SubTask、工具输出缓存、用户偏好	实时写入，会话结束清空
长期知识记忆	pgvector 向量库 + Neo4j 图库	历史案例向量化、CVE/漏洞库、ATT&CK 技战术映射、资产关联图谱、合规框架	外闭环复盘 Agent 自动更新
情景经验记忆	Neo4j + 模式库	成功/失败任务模式、工具使用最佳实践、各场景决策偏好（应急优先速度，挖洞优先深度）	模式提取 Agent 周期性挖掘

知识反馈闭环：

当前任务上下文 → 向量库检索相似历史案例 → 加载相关 ATT&CK 技战术
→ 执行动作 → 产生结果 → 提取模式 → 反哺向量库和场景模板库

七、技术选型建议

层次	建议方案	理由
后端框架	Go（主体）+ Python（AI 推理微服务）	Go 高性能、并发好，适合编排引擎和工具调度；Python AI 生态丰富，适合 LLM 调用和数据分析
前端	React + TypeScript	审计面板、DAG 可视化、决策链路追溯、实时态势看板
向量数据库	pgvector 或 Milvus	历史案例语义搜索；pgvector 可复用 PostgreSQL，Milvus 适合大规模场景
图数据库	Neo4j	攻击路径建模、资产关联、决策证据链（Audit Trail Graph）
任务队列	NATS 或 RabbitMQ	Agent 间异步通信，支持 DAG 依赖编排
沙箱环境	Docker + gVisor	隔离工具执行，防止渗透工具影响宿主机；生产环境建议独立 Worker 节点
可观测性	OpenTelemetry → Grafana + Jaeger + Loki	审计链路复用分布式 Trace（每个 SubTask 为一个 Span）
LLM 网关	多 Provider 抽象层（借鉴 PentAGI）	支持 OpenAI / Anthropic / 本地模型切换，降低单点依赖风险

八、消息链与上下文管理

借鉴 PentAGI 的 ChainAST 压缩方案，针对防御场景做调整：

参数	PentAGI 默认	防御体系建议	原因
尾部保留大小	50KB / 75KB	128KB（Assistant）	防御任务上下文更大（告警、日志、IOC）
保留 QA 段数	7-10	5	防御场景更强调当前状态而非对话历史
压缩触发阈值	未明确	Token 使用率达到 70% 时触发	给后续推理预留足够空间
关键信息锁定	无	关键实体（IP/CVE/资产ID）标记为不可压缩	防止压缩丢失关键上下文

九、与 PentAGI 的关键区别总结

维度	PentAGI（攻击侧）	本方案（防御智能体）
定位	纯攻击，渗透测试	攻防兼备，侧重防御决策
场景覆盖	单一（渗透测试）	多场景（应急响应 / 漏洞挖掘 / 逆向分析 / 渗透测试 / 合规检查）
决策可解释性	无，黑盒决策	核心特性 ——每步决策携带 rationale + evidence 完整审计链
编排模型	线性 Flow → Task → SubTask	DAG 编排，支持并行 + 动态重规划
Agent 体系	11 种（以攻击执行为核心）	11 种（新增 Perceiver/Analyst/Responder/Auditor/Operator，强化防御认知与运维保障）
安全管控	仅沙箱隔离	沙箱 + 四级操作门禁 + 风险熔断 + 人工审批接口
鲁棒性	重试 + 监督 + 反思	重试 + 监督 + 反思 + 检查点回滚 + 熔断 + 确定性保证 + 对抗干扰防护
知识体系	渗透工具知识 + 漏洞库	防御知识 + ATT&CK + CVE + 威胁情报 + 合规框架 + 资产图谱
记忆机制	三类记忆联动	复用 + 增强：防御经验模式存储、场景偏好学习

十、实施路径建议

阶段	目标	关键产出
Phase 1：基础框架	搭建核心编排引擎 + 单场景（应急响应）MVP	DAG 编排器、Perceiver/Analyst/Responder/Operator 四 Agent、基础审计链、沙箱环境
Phase 2：多场景扩展	接入渗透测试、漏洞挖掘场景，建立场景路由	场景知识库模板、Planner 强化、动态重规划
Phase 3：鲁棒性增强	完善监督治理体系，实现双闭环	Auditor 门禁、熔断机制、外闭环经验进化、对抗干扰防护
Phase 4：可视化与审计	决策链路可视化，审计面板，合规报告自动生成	决策时间线视图、证据链图、一键审计报告导出

总结：本方案的核心思路是在 PentAGI 验证过的多 Agent 协作 + 多层监督工程范式基础上，针对防御场景做四个关键突破：

1. **决策可解释性与审计体系**——每个决策携带完整的 rationale + evidence 链路

2. **多场景认知框架**——从单渗透扩展为场景感知的动态路由 DAG 编排，覆盖渗透/应急/挖洞/逆向/运维/合规
3. **运行鲁棒性体系**——从简单的重试+反思，升级为对抗防护+检查点+熔断+确定性保证的完整韧性框架
4. **运维保障层**——Operator Agent 提供系统健康巡检、配置合规、补丁管理、备份恢复的自主运维能力，确保防御体系自身的高可用性